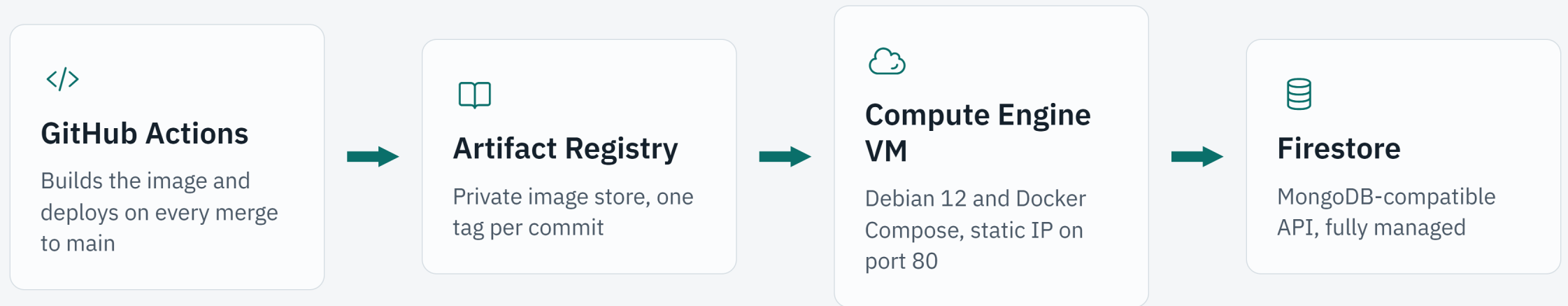


Profile App on GCP

A Node.js app on Compute Engine with Firestore, deployed by GitHub Actions with no stored credentials.

Architecture



Terraform creates all of it: network, firewall, VM, Firestore, registry and IAM.

No keys. No passwords.

GitHub → GCP

Workload Identity Federation swaps GitHub's OIDC token for a one-hour service-account token.

Runner → VM

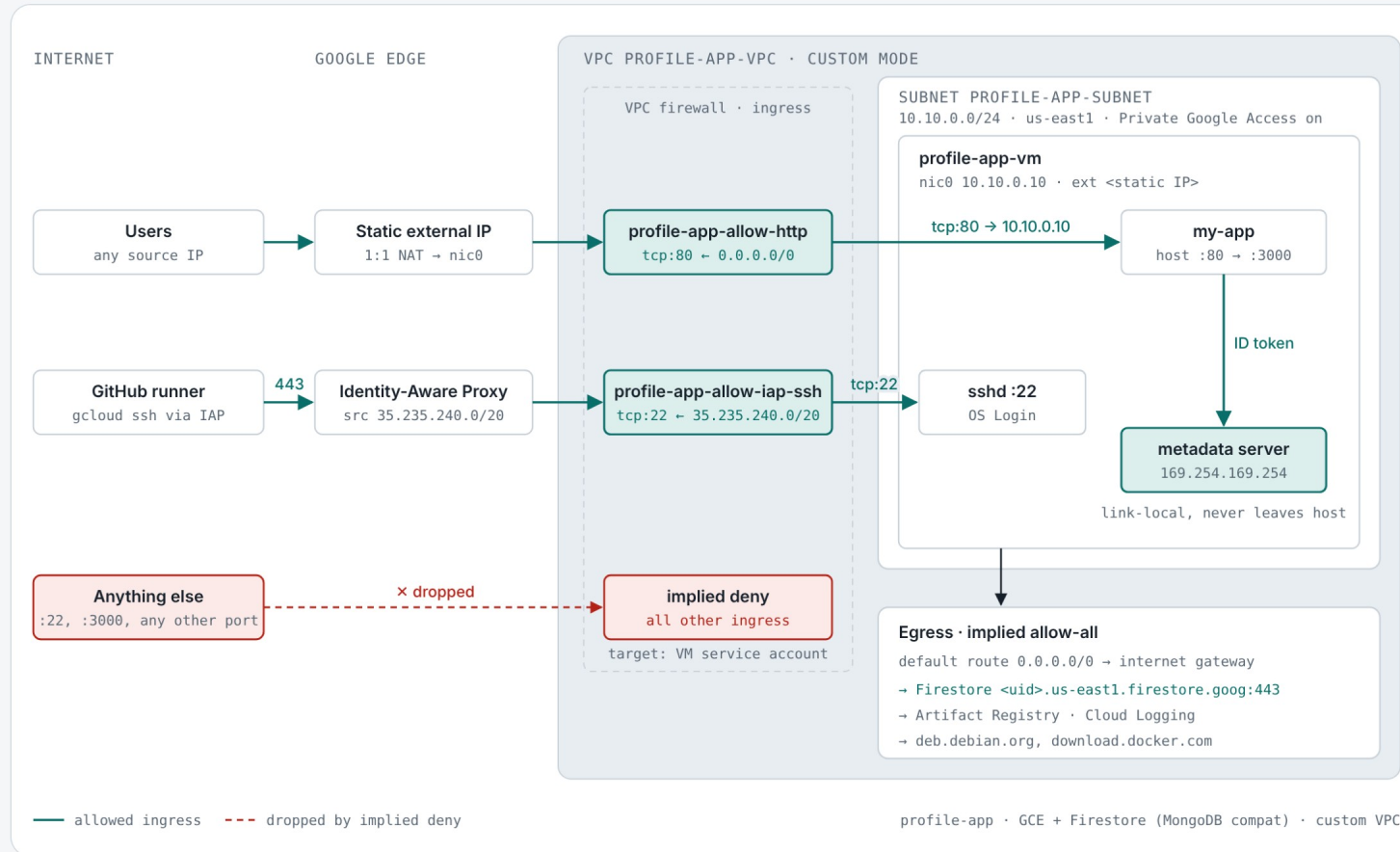
SSH only through Identity-Aware Proxy. OS Login issues a temporary key per run.

App → Firestore

MONGODB-OIDC: the VM's service account signs in. No database password exists.

Each identity does one job (deploy, plan or apply) and only works from **main**.

Networking



Port 80: open

The app, from anywhere

Port 22: IAP only

From 35.235.240.0/20, never the internet

Everything else: dropped

The VPC's implied deny rule

Database: outbound 443

No inbound rule needed

Two pipelines

Infrastructure

`terraform.yml`

1. Pull request: plan posted as a comment
2. Merge to main: plan again
3. You approve in the infra environment
4. Apply the exact plan you reviewed

App

`deploy-gce.yml`

1. Merge to main
2. Build the image, push to the registry
3. Deploy to the VM through IAP
4. Health check and a real Firestore read

Each runs only when its own files change, so app-only PRs never touch Terraform.

Next steps

HTTPS

A domain and an automatic Let's Encrypt certificate

Uptime alerts

Cloud Monitoring checks /healthz and emails on failure

Automatic rollback

A failed health check restores the previous image

Automatic patching

Security updates on the VM without manual SSH

Questions?